BioAuth Optimizer: многокритериальная оптимизация параметров биометрической аутентификации

От формул СРО1 к серверу авторизации с биометрическим входом и калибровкой порогов

Мекенбаев Даниэль Кайратханович, магистрант 2 курса, группа ИС_НПМ_25р

Дисциплина «Методы и инструменты оптимизации» · СРО2 · Университет «Туран», Алматы, 2026

Пороги и факторы выбирают без учёта цены ошибок

1

Порог по EER

Точка равных ошибок уравнивает FAR и FRR, но пропуск мошенника обычно в десятки раз дороже отказа клиенту.

2

Состав факторов «на глаз»

Лицо, отпечаток, FIDO2, SMS: 31 комбинация из пяти факторов, ограничения по времени, бюджету, FAR и защите от подделок.

3

Порог не обновляется

Найденное значение не попадает в рабочую систему и устаревает при смене модели и условий съёмки.

Цель работы

Решения по расчёту, а не по привычке

Минимум ожидаемых потерь E при заданных стоимостях ошибок и ограничениях — с доказательством оптимальности и проверкой на реальных данных.

Метод из СРО1: две задачи оптимизации

Задача 1. Оптимальный порог

$$E(\tau) = c_{FA} \cdot FAR(\tau) + c_{FR} \cdot FRR(\tau) \rightarrow min$$

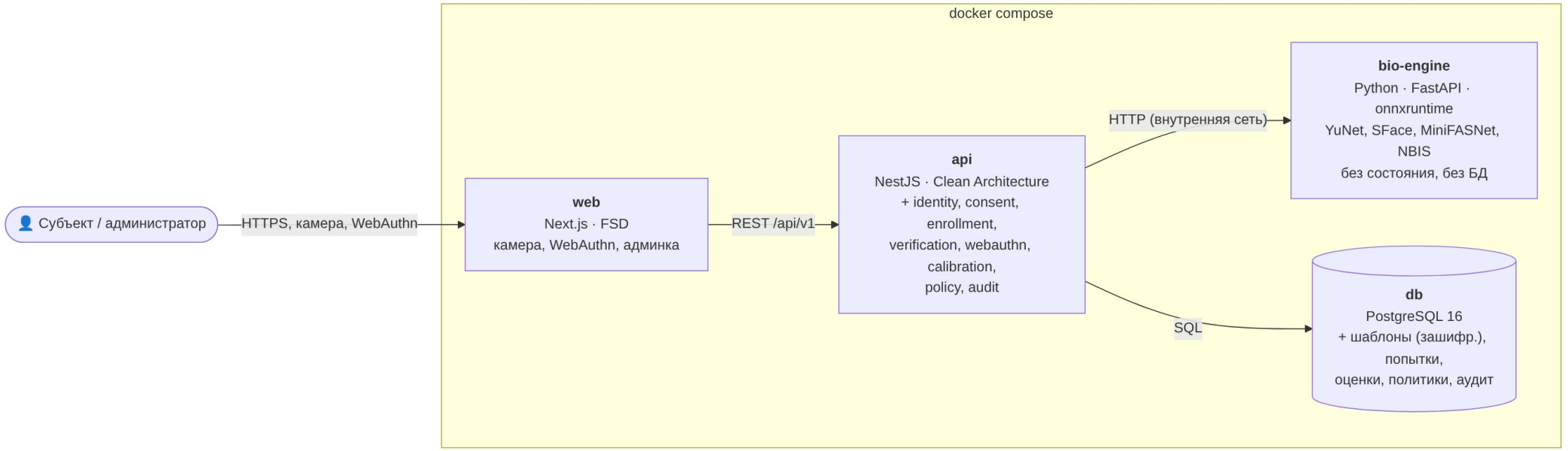
- нормальная модель: аналитическое решение квадратного уравнения + численная проверка
- свои оценки (CSV): точный перебор всех порогов за O(n log n)
- ограничение FAR(τ) ≤ FARmax

Задача 2. Состав факторов

$$min\ E(x),\ \ x \in \{0,1\}^n$$

- правило «И»: FAR = ∏FAR$_i$, FRR = 1 − ∏(1 − FRR$_i$)
- ограничения: задержка, бюджет, FAR набора, факторы с PAD
- ln FAR = Σ x_i·ln FAR$_i$ — точная линеаризация → ЦЛП (HiGHS) с сертификатом оптимума

Архитектура: модульный монолит и сервис bio-engine



Ядро

TypeScript, чистые функции, без фреймворков — расчёты отдельно от инфраструктуры

Сервер

NestJS, Clean Architecture: модули, порты и адаптеры, zod-контракты

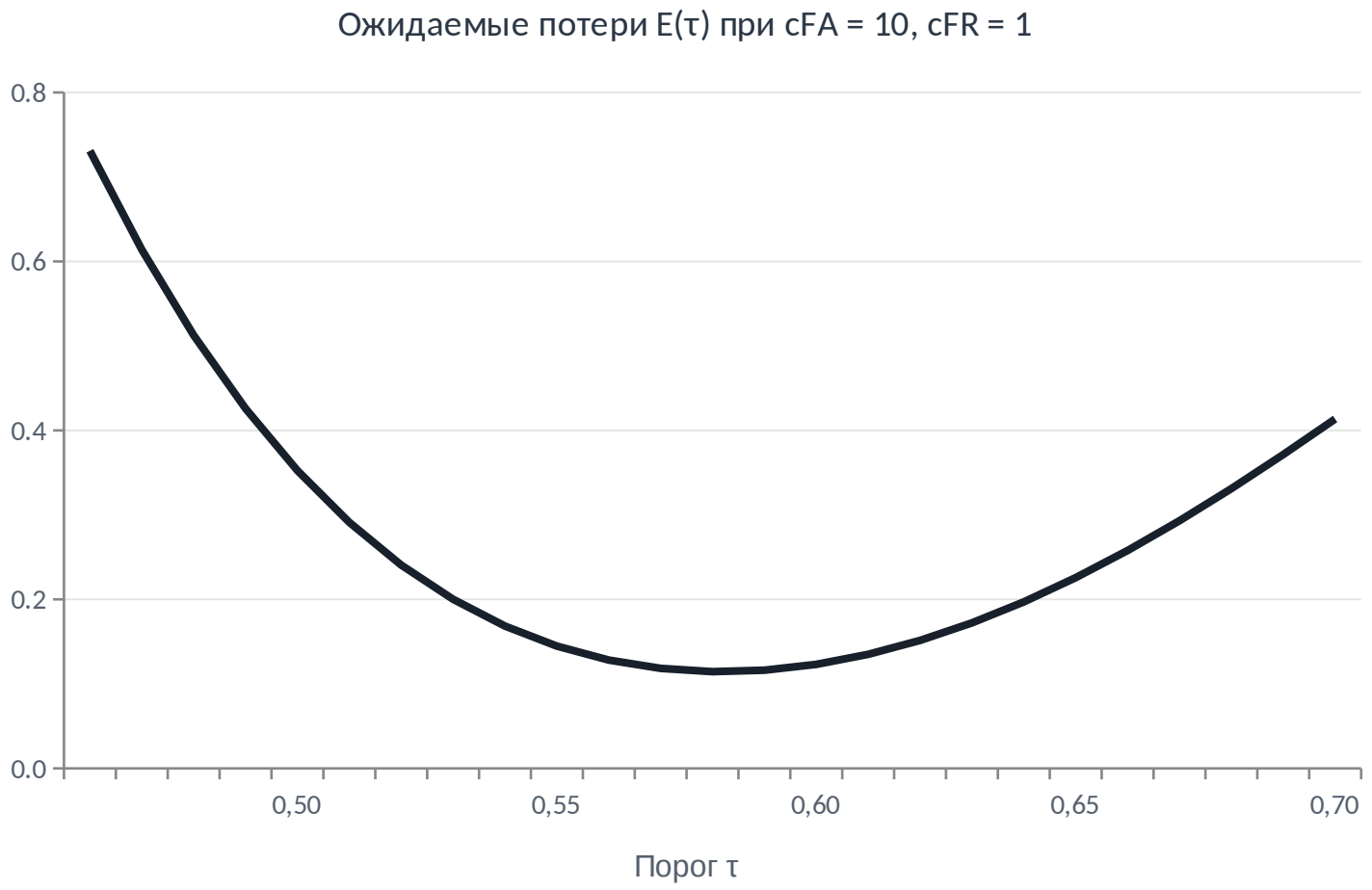
Интерфейс

Next.js, Feature-Sliced Design, проверка слоёв линтером steiger

bio-engine

Python, ONNX Runtime: лица и «живость»; без состояния, во внутренней сети

Порог: потери на 41,8 % ниже, чем при EER



0,531 → 0,5818

порог: EER → оптимальный τ*

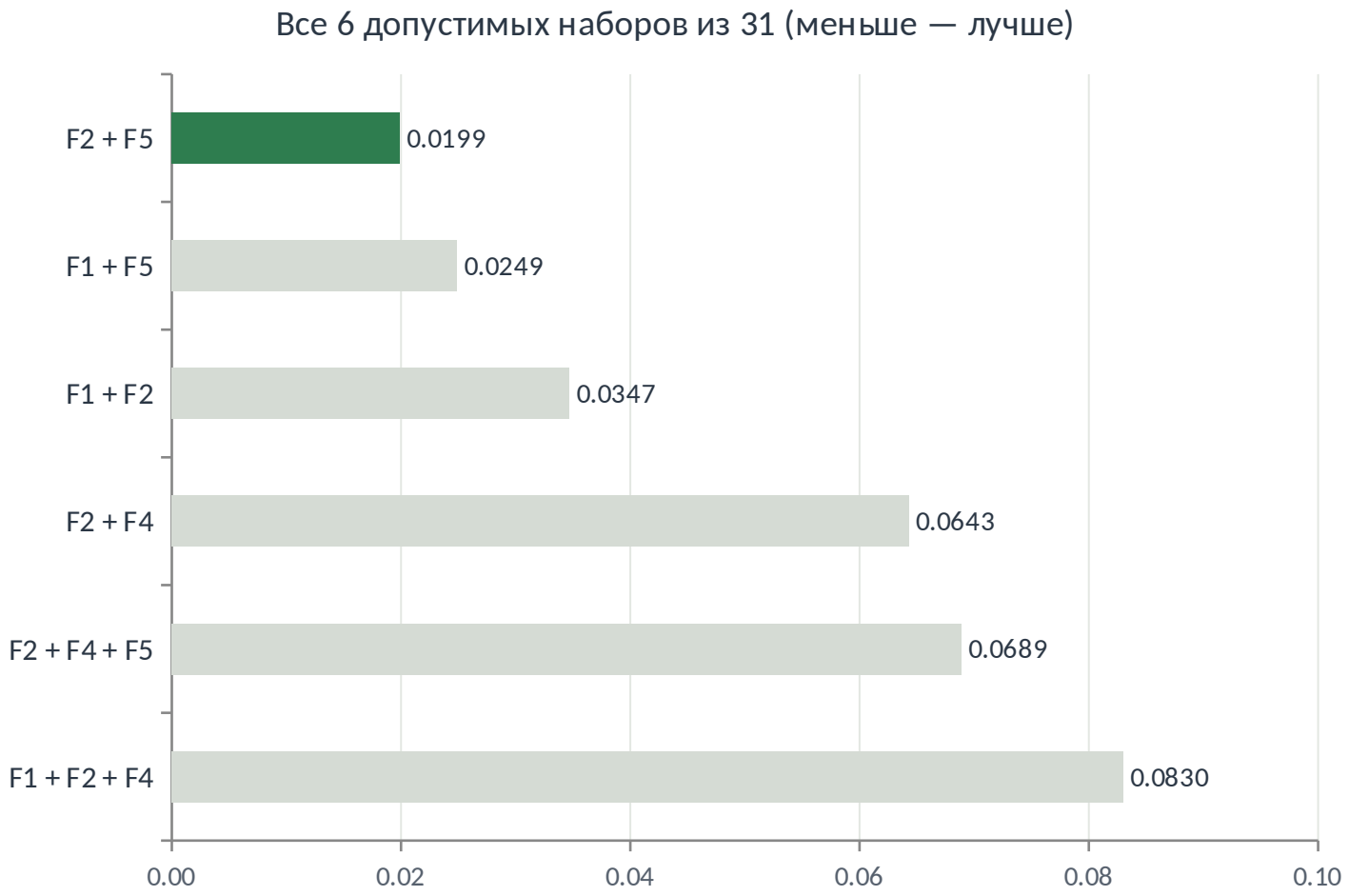
0,1965 → 0,1144

ожидаемые потери E

−41,8 %

снижение потерь; FAR 1,79 % → 0,52 % ценой FRR 6,2 %

Состав факторов: оптимум F2 + F5 с доказательством



F2 + F5

отпечаток + аппаратный ключ FIDO2, E = 0,019925

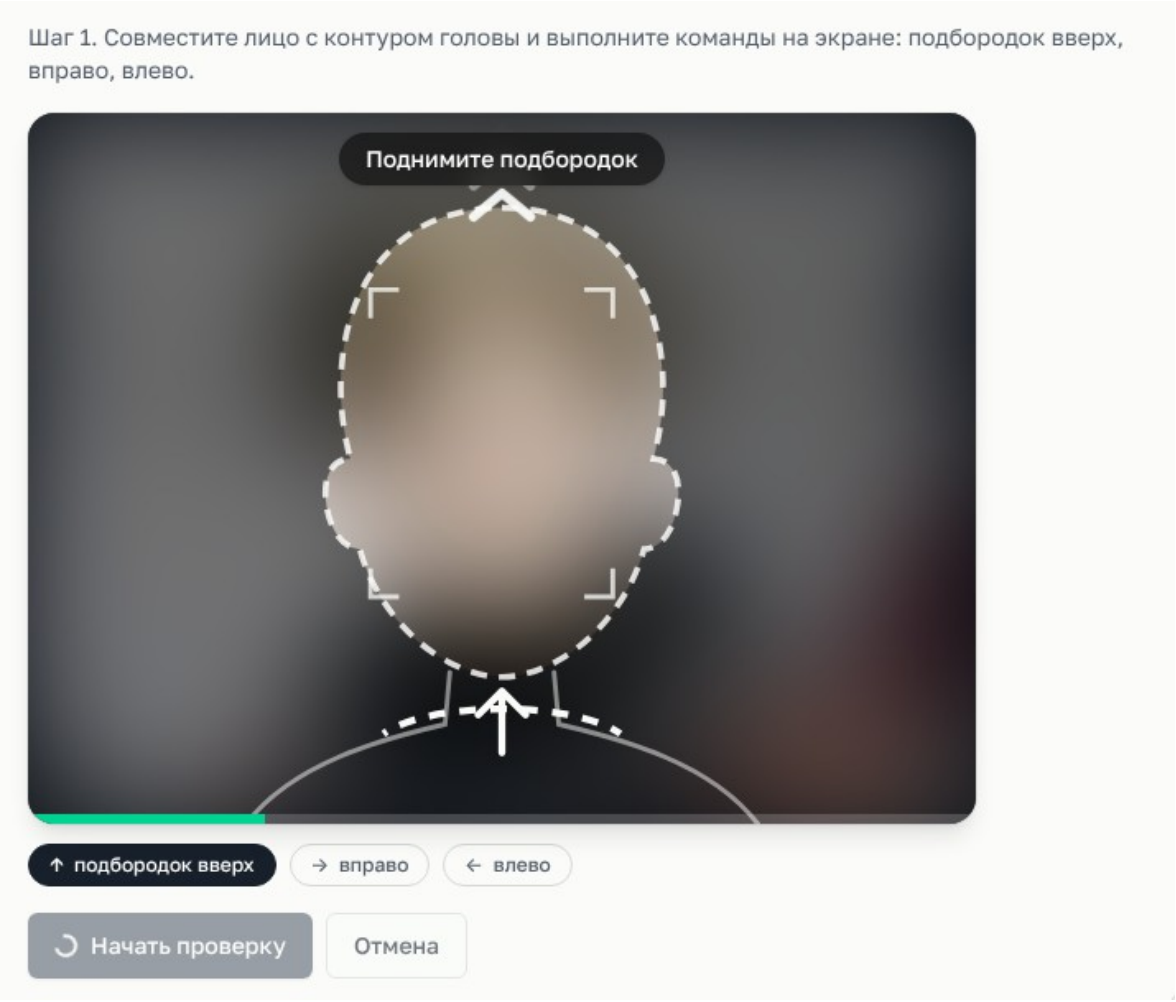
2 итерации

ЦЛП по фронту Парето: нижняя граница доказывает оптимум

× 1,74

рост потерь при сокращении бюджета 2,5 → 2,0 (оптимум F1 + F2)

Версия 2: настоящий вход по лицу и passkey



1

Распознавание

YuNet → контроль качества → SFace; модели закреплены по SHA-256

2

«Живость»

MiniFASNet + три случайные команды; контур головы и стрелки подсказывают движение

3

Второй фактор

Passkey (WebAuthn) с отпечатком или Face ID на устройстве

4

Защита данных

Кадры не хранятся; шаблон — AES-256-GCM и отменяемая проекция; журнал аудита с цепочкой хэшей

Замкнутый контур: измерение → расчёт → политика

1

Попытки входа

оценки сходства и «живости» с версией модели

2

Достаточность

правило трёх: FAR ≤ 3/n подтверждён данными

3

Ядро v1

тот же расчёт порога, ядро не менялось

4

Политика

действует после утверждения администратором

↻ новая политика порождает новые попытки — контур повторяется; рост FRR за неделю (z > 2) сигнализирует о дрейфе

Испытание PAD

APCER по видам атак и BPCER, ISO/IEC 30107-3

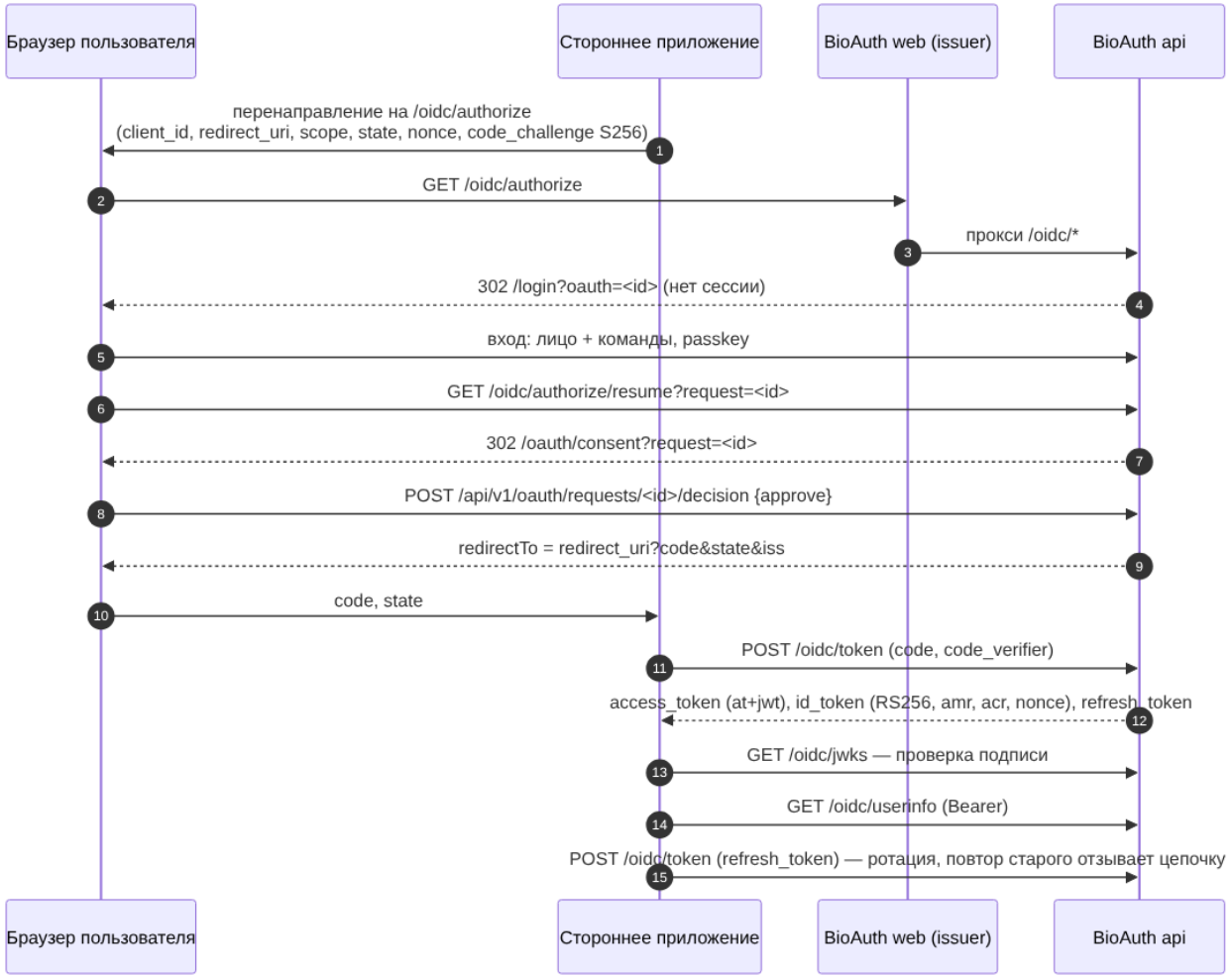
Пакетный режим

архив изображений → тысячи сравнений для малого FAR

Протокол «до/после»

FAR, FRR с интервалами Уилсона и E на одних данных

Версия 3: биометрический вход для других сервисов



1 **OpenID Connect**

код авторизации + PKCE S256, refresh с ротацией, client credentials, userinfo, JWKS

2 **Как проверен**

ID-токен RS256 с amr (face, hwk) и acr — приложение не получает биометрию

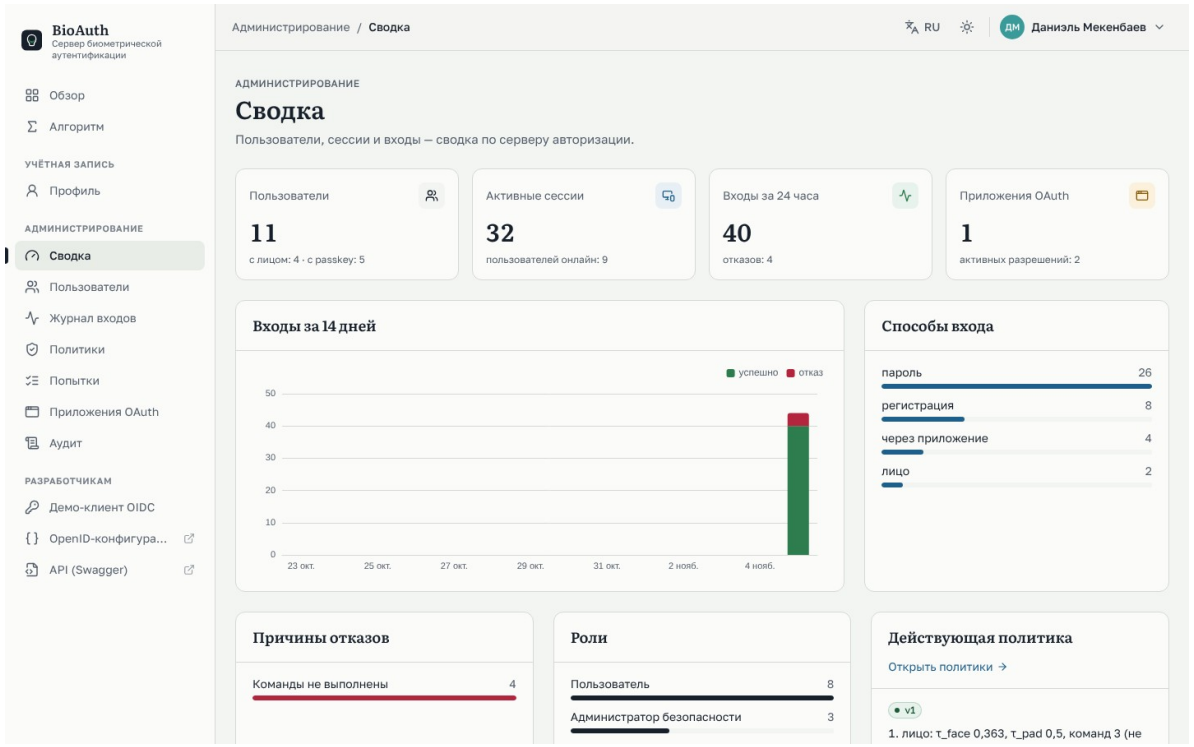
3 **Защита**

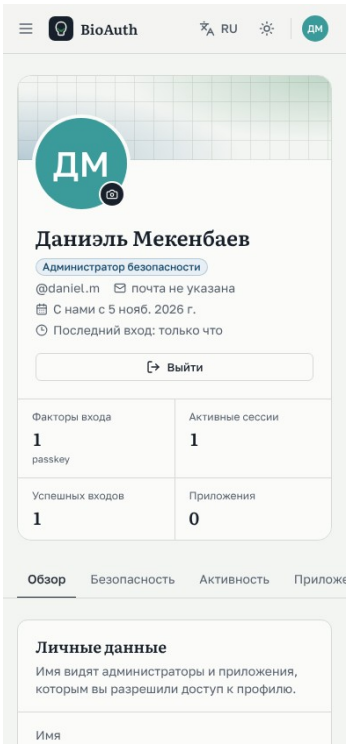
коды и токены — только хэши; ключ подписи зашифрован; повтор refresh отзывает цепочку

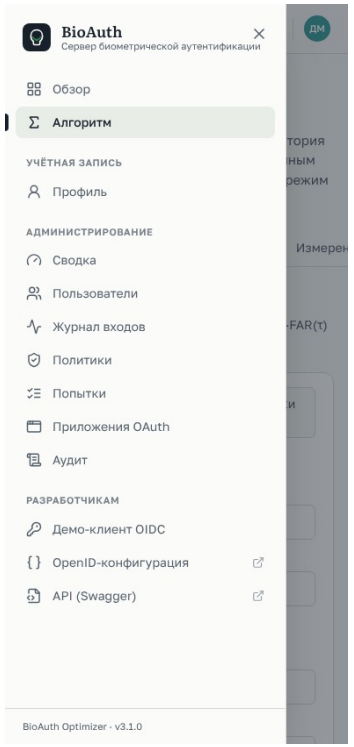
4 **Подключение**

клиенты регистрирует администратор, секрет показывается один раз; демо-клиент в интерфейсе

Профиль, админ-панель, мобильная версия и PWA







Профиль

фото с камеры, сессии на устройствах, история входов, подключённые приложения

Админ-панель

сводка, пользователи и роли, отключение, журнал входов, клиенты OAuth, аудит

Интерфейс

русский, казахский, английский; тёмная тема; телефон; установка как PWA; SEO

Качество: 293 автоматических теста и CI

103 ядро: пример статьи, 50 эталонов SciPy, property-тесты

74 сервер: сценарии и e2e на PostgreSQL, OpenID Connect

68 bio-engine: модели на эталонных портретах

18 контракты api ↔ bio-engine

18 интерфейс: числа, подсказки камеры, съёмка

12 браузер: камера, WebAuthn, OIDC, PWA

- совпадение с SciPy до 10^{-12}
- два независимых решателя согласны на случайных задачах
- GitHub Actions: линтеры, типы, тесты, Docker Compose и e2e на каждый push

Выводы и вклад в диссертацию

1

Методы CPO1 реализованы полностью

порог по минимуму E и состав факторов с доказанным оптимумом; пример статьи воспроизведён точно

2

Расширяемая архитектура

SOLID, Clean Architecture, FSD: версии 2 и 3 построены без изменения ядра

3

Живые данные и сервер авторизации

вход по лицу и passkey, калибровка с проверкой достаточности; OpenID Connect для других сервисов

4

Для диссертации

испытание «до/после калибровки» на добровольцах по готовому протоколу — эмпирическая глава и статья

github.com/DcNi3L/bioauth-optimizer · Спасибо за внимание